Microsoft Purview SOX Compliance Program

Implementation Solution Guide

Version 1.0.0 · 2026-07-07

Contents

Executive Summary — Microsoft Purview SOX Compliance Program 5

The problem . . . 5

The solution . . . 5

What you get . . . 5

Approach . . . 5

Boundaries . . . 6

The bottom line . . . 6

1. Solution Overview — Microsoft Purview SOX Compliance Program 6

What this solution is . . . 6

Why this matters . . . 6

How it works . . . 7

The SOX control map this solution configures (Purview → ITGC objective) . . . 7

Evidence runbooks (the artifacts an auditor requests) . . . 8

What you can control . . . 8

Limitations (be honest with buyers) . . . 8

Naming convention (used in every doc and script) . . . 8

The standard deployment model . . . 9

2. Requirements Guide — Microsoft Purview SOX Compliance Program 9

2.1 Compliance licensing for the SOX control set . . . 10

2.2 Least-privilege Purview roles (with SOX-relevant separation) . . . 10

2.3 Security & Compliance PowerShell + Exchange Online PowerShell + Graph . . . 10

2.4 Unified audit logging enabled (the evidence foundation) . . . 10

2.5 Defined SOX scope: financial data, systems, and records schedule . . . 11

2.6 Compliance Manager assessment for SOX/ICFR (if using) . . . 11

2.7 A pilot scope and change window . . . 11

Global Requirements — Microsoft Purview Solutions 11

1. Microsoft 365 tenant with the required Purview/compliance licensing . . . 12

2. Purview roles (least-privilege) and portal access . . . 12

3. Security & Compliance PowerShell + Graph toolchain . . . 12

4. Data sources & scope in scope . . . 13

5. Compliance, records, privacy & legal stakeholders . . . 13

6. A pilot scope and change control . . . 13

3. Implementation Guide — Microsoft Purview SOX Compliance Program 14

Step 1 — Assess current state and licensing (Assess) . . . 14

Step 2 — Map SOX objectives to Purview controls (Design) . . . 14

Step 3 — Enable the evidence foundation: unified audit (Configure) . . . 14
Step 4 — Configure the financial-data classification (Configure → Pilot) . . . 15
Step 5 — Configure the financial-data DLP policy in SIMULATION (Configure → Pilot) . . . 15
Step 6 — Configure SOX records retention (Configure → Pilot) . . . 15
Step 7 — Configure the financial-access audit retention policy (Configure) . . . 16
Step 8 — Map the controls in Compliance Manager (Configure) . . . 16
Step 9 — Build the evidence runbooks (Configure) . . . 16
Step 10 — Validate the program and its evidence (Validate) . . . 17
Step 11 — Expand to enforcement and operationalize (Expand) . . . 17
5. Testing & Validation — Microsoft Purview SOX Compliance Program 17
Gate 1 — Unified audit logging is on (evidence foundation) . . . 17
Gate 2 — Licensing supports the advanced controls . . . 18
Gate 3 — Financial-data label exists and applies on the pilot . . . 18
Gate 4 — DLP policy is present and in SIMULATION mode . . . 18
Gate 5 — DLP simulation is registering matches . . . 18
Gate 6 — SOX records retention policy is scoped and correct . . . 18
Gate 7 — Financial-access audit retention policy exists . . . 19
Gate 8 — Evidence runbooks answer the auditor's questions . . . 19
Gate 9 — Segregation of duties on the controls themselves . . . 19
Gate 10 — Compliance Manager assessment reflects the controls . . . 19
Gate 11 — Program scorecard is green (pilot, then tenant-wide) . . . 19
Evidence to retain . . . 20
6. Troubleshooting — Microsoft Purview SOX Compliance Program 20
Unified audit evidence is empty for the review period (the foundation) . . . 20
The financial-data label doesn't appear for pilot users . . . 20
The DLP policy is blocking users during the pilot . . . 21
DLP simulation shows no matches for financial content you expect it to catch . . . 21
Retention or audit-retention create fails on duration or priority . . . 21
Retention-policy / DLP / label cmdlet "term is not recognized" . . . 21
An evidence runbook returns nothing for activity you know happened . . . 21
Compliance Manager score didn't move after configuring a control . . . 22
Segregation-of-duties gate fails — same person configures and reviews . . . 22
When to escalate beyond this solution . . . 22
7. Best Practices — A Defensible SOX Program in Microsoft Purview 22
Treat evidence as the deliverable, not the control . . . 22
Map controls to objectives explicitly — and keep the map current . . . 23

Pilot every high-impact control — DLP in simulation, always . . . 23
Classify deliberately, then let protection key off the label . . . 23
Retention: configure to the schedule, never invent one . . . 23
Segregation of duties — on the ERP *and* on Purview itself . . . 23
Watch the gotchas that undermine SOX evidence . . . 24
Monitor for drift between audits . . . 24
Verify against your tenant — Purview evolves . . . 24
8. Deliverables Summary — Microsoft Purview SOX Compliance Program 24
Documentation . . . 24
PowerShell tools (5) . . . 25
Named artifacts created . . . 26
Definition of done . . . 26
Appendix A — PowerShell Scripts 27

Executive Summary — Microsoft Purview SOX Compliance Program

The problem

The Sarbanes-Oxley Act holds leadership accountable for the integrity of financial reporting — and, in practice, for the **IT general controls** around the data and systems that produce it: who can access financial data, how change is controlled, whether activity is logged, and whether records are retained. When an external auditor tests those controls, the recurring failure isn't that the controls are absent — it's that they were never **mapped to a tool**, never **configured consistently**, and there is **no evidence** to hand over. Several of those artifacts naturally live in Microsoft Purview, but only if someone deliberately makes them exist.

The solution

A complete, self-guided **SOX-aligned program built inside Microsoft Purview**. It **maps** the relevant ITGC objectives — access to programs and data, change management, IT operations, segregation of duties, records retention — to concrete Purview controls; **configures** those controls (a financial-data **sensitivity label**, a **DLP policy piloted in simulation**, a **retention policy** for SOX records, **unified audit** with a retention policy scoped to financial-data access, and least-privilege **roles**); rolls them up in **Compliance Manager**; and produces the **audit evidence** an ICFR review will ask for. Five safe-by-default PowerShell tools (read-only or `-WhatIf` until you commit) do the scoping, discovery, configuration, validation, and evidence reporting.

What you get

- **A control map, made concrete** — each Purview control tied to the ITGC objective it evidences, maintained in Compliance Manager.
- **The evidence foundation confirmed** — unified audit logging on, so financial-data access and control changes are captured (audit is not retroactive — this happens first).
- **Financial data classified and protected** — one clear label, a DLP policy that runs in **simulation** to show exposure before it ever blocks, and a retention policy set to your records schedule.
- **Evidence runbooks** — the exact searches for the auditor's recurring requests: who accessed financial data, who changed a control, who was granted access — with a paged search tool that never silently truncates.
- **Proven readiness** — a control-to-evidence scorecard that confirms each control operates and its artifact is producible, before the auditor asks.

Approach

Delivery follows a disciplined, reversible model — **Assess** → **Design** → **Configure** → **Pilot (simulate)** → **Validate** → **Expand** — with DLP and every high-impact control **piloted in simulation/test on a finance ring** before tenant-wide enforcement, and pass/fail gates and documented rollback at every step.

Boundaries

The advanced controls (content-aware DLP, auto-labeling, long-term audit retention, Compliance Manager templates) are **licensing-/plan-dependent** — E5 or the E5 Compliance add-on — and the Purview portal is **actively evolving**; capabilities and paths are cited or flagged **"verify your licensing/tenant,"** never assumed. This is **not an audit or an attestation**: **SOX control-design adequacy, operating-effectiveness conclusions, materiality, record-retention schedules, and legal holds are deferred to your management, internal-audit, records, and legal functions** — the solution provides the technical method and the evidence, not the determination.

The bottom line

A SOX-aligned Purview program **mapped, configured, piloted, and validated** — with the audit evidence ready before you need it, so an ICFR review finds **controls and artifacts, not gaps**.

1. Solution Overview — Microsoft Purview SOX Compliance Program

What this solution is

The Sarbanes-Oxley Act (SOX) holds a company's leadership accountable for the integrity of financial reporting — and, in practice, for the **IT general controls (ITGCs)** around the systems and data that produce those reports: who can access financial data, how changes are controlled, whether activity is logged, and whether records are retained. When an external auditor tests those controls, the recurring failure is not that the controls don't exist — it's that they were never **mapped to a tool**, never **configured consistently**, and there is **no evidence** to hand over. This solution delivers a SOX-aligned program **inside Microsoft Purview**: it **maps** the relevant ITGC objectives (access to programs and data, change management, IT operations, segregation of duties, records retention) to concrete Purview controls, **configures** those controls — a financial-data **sensitivity label**, a **DLP policy piloted in simulation**, a **retention policy** for SOX records, **unified audit** with a retention policy scoped to financial-data access, and least-privilege **roles** — and produces the **audit evidence** an ICFR review will ask for. It uses only the **Microsoft Purview portal**, **Security & Compliance PowerShell** (`Connect-IPPSSession`), **Exchange Online PowerShell**, and **Microsoft Graph** — no third-party tooling.

Why this matters

- **SOX is evidenced, not asserted.** An auditor tests whether a control operated over the period — that requires an artifact (a policy that was in force, an audit trail of access, a change log). Purview is where several of those artifacts naturally live; this solution makes them exist and be exportable.
- **ITGCs are the common audit finding.** Access-to-data, change-management, and IT-operations controls are where financially-relevant IT deficiencies concentrate. Classifying financial data, restricting and monitoring its access, controlling policy change, and retaining the audit trail address exactly those.
- **Audit is not retroactive.** The unified audit log only holds what was captured after logging was enabled. If financial-data access wasn't being logged during the period under review, the evidence simply isn't there — so the foundation is confirmed first, before anything else.

• **The controls are licensing-dependent and evolving.** Advanced DLP, auto-labeling, long-term audit retention, and **Compliance Manager** assessment templates require **Microsoft 365 E5** or the **E5 Compliance** add-on; some are in preview and the Purview portal changes. This solution confirms what your tenant actually has rather than assuming, and flags **"verify your licensing/tenant"** where availability varies.

How it works

1. **Assess the current state.** Confirm unified audit logging is on, inventory any existing SOX-relevant labels / DLP / retention / audit-retention policies and Purview role assignments, and check the licensing that gates the advanced controls.

2. **Map SOX objectives to Purview controls.** With your SOX/ICFR owners and external-audit expectations, agree which ITGC objective each Purview control satisfies — the mapping is the backbone of the program and of the **Compliance Manager** assessment.

3. **Configure the controls — pilot-first.** Create the financial-data sensitivity label, the DLP policy **in simulation/test mode**, the retention policy on a limited pilot scope, and the audit retention policy for financial-data access — every write previewed with `-WhatIf` and scoped to a pilot ring before any enforcement.

4. **Validate operation and evidence.** Confirm each control exists and is in its expected state, DLP is capturing matches in simulation, labels apply, audit shows financial-data access, and each **evidence runbook** returns the artifact an auditor will request.

5. **Expand to enforcement.** Once the pilot passes, move DLP from simulation to enforce, extend label/retention/audit coverage to full scope, and schedule the read-only discovery/report chain so control drift is caught between audits.

The SOX control map this solution configures (Purview → ITGC objective)

Purview control (named artifact)	SOX / ITGC objective it evidences
`Financial – SOX Reporting – Confidential` (sensitivity label)	**Access to programs & data** — financial reporting data is classified so protection and monitoring can key off it.
`DLP – SOX Financial Data – Simulation` (DLP policy, simulation first)	**Access to programs & data** — prevents/monitors exfiltration of classified financial data; simulation provides evidence of exposure before enforcement.
`Retention – SOX Financial Records – Governed` (retention policy)	**Records retention** — retains financially-relevant records for the schedule your records/legal function sets (duration is their determination).
`Audit Retention – Financial Data Access – SOX` (audit log retention policy)	**IT operations / monitoring** — the who/what/when access trail is captured and kept for the review period.
Least-privilege Purview roles + privileged-action audit	**Segregation of duties & change management** — configuration change is restricted and logged.
`SOX ICFR – Purview Controls – Assessment` (Compliance Manager)	**Control mapping & evidence** — the Purview controls above rolled up as ICFR improvement actions with evidence (verify template availability for your licensing).

Evidence runbooks (the artifacts an auditor requests)

- `Evidence – Financial Data Access – Runbook` — who accessed labeled financial content, over a period.
- `Evidence – Control Change Management – Runbook` — who changed a DLP / label / retention / role configuration.
- `Evidence – Access Provisioning – Runbook` — role/group additions granting access to financial data.

What you can control

- Which data is **classified** as SOX-relevant financial reporting data (the label and its scope).
- Whether the financial-data **DLP** policy is in **simulation** or **enforce**, and what it acts on.
- Which record types / operations / users get **extended audit retention**, and for how long (within licensing).
- The **pilot scope** (`SOX Pilot – Finance Ring – Stage1`) validated before any tenant-wide enforcement.
- The **control-to-objective mapping** and which evidence runbooks are in scope.

Limitations (be honest with buyers)

- **This is not an audit or an attestation.** The solution configures Purview controls and produces evidence; it does not opine on SOX compliance, materiality, or ICFR design/operating effectiveness — that is the work of management, internal audit, and the external auditor.
- **Regulatory, records-retention, and legal determinations are deferred.** SOX record-retention periods (e.g. audit-workpaper retention under §802), which data is financially relevant, legal holds, and control-design decisions belong to your **compliance, records, internal-audit, and legal** functions — this solution provides the technical method and evidence, not the determination.
- **Premium features are license-gated.** Advanced DLP, auto-labeling, long-term audit retention, and Compliance Manager templates require **E5 / E5 Compliance**; some are preview. **Verify your licensing/tenant.**
- **Audit is not retroactive.** Enabling logging today creates no history for the prior period. Value accrues from the enablement date forward.
- **Purview is one layer of ITGC coverage.** It addresses data classification, DLP, retention, and the M365 audit trail; it does **not** replace application-level access controls in your ERP/financial systems, SoD tooling, or change-management systems — coordinate the program with those.

Naming convention (used in every doc and script)

Every artifact this solution creates is named `<Purpose> – <Scope> – <Stage>` and reused verbatim across the docs, scripts, and portal. The standard set:

Artifact	Name
Financial-data sensitivity label	`Financial – SOX Reporting – Confidential`
Financial-data DLP policy (simulation first)	`DLP – SOX Financial Data – Simulation`
SOX records retention policy	`Retention – SOX Financial Records – Governed`
Financial-access audit retention policy	`Audit Retention – Financial Data Access – SOX`
Compliance Manager assessment	`SOX ICFR – Purview Controls – Assessment`
Financial-data-access evidence runbook	`Evidence – Financial Data Access – Runbook`
Control-change evidence runbook	`Evidence – Control Change Management – Runbook`
Access-provisioning evidence runbook	`Evidence – Access Provisioning – Runbook`
Program evidence scorecard export	`SOX Program – Purview Controls – Report`
Pilot validation scope	`SOX Pilot – Finance Ring – Stage1`

The standard deployment model

> *Assess the current audit/licensing/control state → design the SOX-to-Purview control map → configure the label, DLP (simulation), retention, and audit controls → **pilot** on a limited finance ring in simulation/test mode → validate each control operates and its evidence is producible → expand to enforcement tenant-wide. Pattern: **Assess** → **Design** → **Configure** → **Pilot (simulate)** → **Validate** → **Expand (enforce).***

2. Requirements Guide — Microsoft Purview SOX Compliance Program

Verify **every** requirement before configuring. Each entry: **Description · Why · Verify · Implement-if-missing.** Category-wide prerequisites (tenant/licensing, Purview roles, the S&C PowerShell + Graph toolchain, in-scope workloads, compliance/records/legal stakeholders, pilot & change control) are in `global-requirements-purview.md` — this guide adds the SOX-specific detail.

> ***Licensing/tenant boundary.** The advanced controls this program relies on — content-aware **DLP**, **auto-labeling**, **long-term audit retention**, and **Compliance Manager** premium assessment templates — require **Microsoft 365 E5** or the **E5 Compliance** add-on, and some are in preview. Where this guide flags "verify your licensing/tenant," confirm the capability is present and the portal path is current before relying on it — Purview evolves. Baseline classification, manual labels, and Audit Standard are available at lower tiers.*
>
> ***Determination boundary.** SOX record-retention periods, which data is financially relevant to ICFR, legal holds, and control-design/operating-effectiveness conclusions are **management, internal-audit, records, and legal determinations** (GR §5). This solution configures to them and produces evidence; it does not make them.*

2.1 Compliance licensing for the SOX control set

Description: Baseline classification, manual sensitivity labels, and **Audit Standard** are broadly available; **advanced DLP** (content-aware conditions, simulation reporting at scale), **auto-labeling**, **long-term audit retention**, and **Compliance Manager premium templates** (a SOX/ICFR-relevant assessment) require **E5** or the **E5 Compliance** add-on. **Why:** Several program controls are plan-gated; the feature won't be available without the right plan (GR §1). **Verify:** M365 admin center → `Billing → Licenses`; and run `PURVSOX-Scope.ps1`, which reads `subscribedSkus`/service plans via Graph and reports whether E5/E5-Compliance-bearing plans are present. Confirm **Compliance Manager** and **DLP** are visible in the Purview portal. **Implement:** Assign/purchase E5 or the E5 Compliance add-on to the in-scope users before expecting the advanced controls; the baseline (manual labels, Audit Standard, basic retention) can proceed at E3.

2.2 Least-privilege Purview roles (with SOX-relevant separation)

Description: The role groups the program touches: **Compliance Administrator** / **Compliance Data Administrator** (labels, DLP, retention), **Information Protection** roles (labels), **Records Management** (retention), **Audit Manager/Reader** (audit search & retention policies), and **Compliance Manager** access. For SOX **segregation of duties**, the person who *configures* a control should not be the sole party who *reviews its evidence* — separate configuring and reviewing roles. **Why:** Purview uses fine-grained role groups; configuration requires the matching role, and SoD is itself a SOX control (GR §2). **Verify:** Purview portal → `Settings → Roles & scopes / Permissions` — confirm memberships. `PURVSOX-Scope.ps1` reports the role groups and their members for review. **Implement:** Assign the least-privilege role groups under change control; document the configure-vs-review separation. Reserve Global Administrator for one-time enablement only.

2.3 Security & Compliance PowerShell + Exchange Online PowerShell + Graph

Description: The `ExchangeOnlineManagement` module provides **both** `Connect-IPPSSession` (Security & Compliance PowerShell — labels, DLP, retention, and the `*-UnifiedAuditLogRetentionPolicy` cmdlets) **and** `Connect-ExchangeOnline` (`Search-UnifiedAuditLog`, `Get/Set-AdminAuditLogConfig`). `Microsoft.Graph` is used for licensing/role reads. **Why:** Configuration, evidence collection, and the provided scripts run through these (GR §3). **Note:** most SOX control cmdlets are S&C PowerShell (`Connect-IPPSSession`); audit search/config is Exchange Online (`Connect-ExchangeOnline`). **Verify:** `Get-Module -ListAvailable ExchangeOnlineManagement`; both `Connect-IPPSSession` and `Connect-ExchangeOnline` succeed with a modern-auth/MFA admin. `PURVSOX-Scope.ps1` connects and reports which endpoints are reachable. **Implement:** `Install-Module ExchangeOnlineManagement -Scope CurrentUser`; `Install-Module Microsoft.Graph -Scope CurrentUser`.

2.4 Unified audit logging enabled (the evidence foundation)

Description: `UnifiedAuditLogIngestionEnabled` must be **true** for the tenant so financial-data access, sharing, label, and configuration-change events are captured. On by default for newer tenants but may be off. **Why:** The audit trail is the primary SOX evidence for IT operations and access; **it is not**

retroactive — nothing is captured while ingestion is off (GR §6 change discipline). **Verify:** `Get-AdminAuditLogConfig | Format-List UnifiedAuditLogIngestionEnabled` (via `Connect-ExchangeOnline`); `PURVSOX-Discovery.ps1` reports the state. **Implement:** `Set-AdminAuditLogConfig -UnifiedAuditLogIngestionEnabled $true` under change control (activation can take time); enable **before** the review period you intend to evidence.

2.5 Defined SOX scope: financial data, systems, and records schedule

Description: A documented statement — **from your SOX/ICFR, finance, records, and internal-audit owners** — of which data and workloads are **financially relevant** (SharePoint sites / Teams / mailboxes / OneDrive holding financial reporting data), which **evidence** the external auditor expects, and the **retention schedule** for SOX records. **Why:** Labels, DLP, and retention key off the in-scope data and the classification/records intent, not technical defaults (GR §4, §5); scoping is a determination, not a guess. **Verify:** You can name the in-scope workloads/sites, the classification intent for financial data, the retention schedule, and named approvers. **Implement:** Capture the scope, classification intent, retention schedule, and evidence expectations before authoring any control.

2.6 Compliance Manager assessment for SOX/ICFR (if using)

Description: Microsoft Purview Compliance Manager with an assessment template that maps to your SOX/ICFR control set (a SOX/SOC-type template, or a custom template) so the Purview controls roll up as **improvement actions** with evidence. **Why:** Compliance Manager is the control-mapping and evidence-rollup surface; it turns the configured controls into an auditable ICFR view. **Verify:** Purview portal → **Compliance Manager** is visible (licensing 2.1); a SOX/ICFR-relevant template is available to add — **verify template availability for your licensing/tenant** (templates and their names differ by plan and evolve). `PURVSOX-Scope.ps1` flags whether Compliance Manager is reachable. **Implement:** Add the SOX/ICFR (or a custom) assessment in Compliance Manager and name it `SOX ICFR – Purview Controls – Assessment`; if no suitable template is licensed, map the controls in a custom assessment or maintain the mapping alongside this guide.

2.7 A pilot scope and change window

Description: A limited **pilot** — a **finance ring** (`SOX Pilot – Finance Ring – Stage1`): a small set of finance users/sites — to validate the label, DLP-in-simulation, retention, and audit controls before tenant-wide enforcement, plus an agreed change window (GR §6). **Why:** DLP, labels, and retention are high-impact; SOX changes must be change-controlled and reversible. **DLP supports a simulation/test mode that MUST be used before enforcement. Verify:** A named pilot scope and change approval exist; DLP simulation mode is available in your tenant. **Implement:** Define the finance-ring pilot and change window before configuring; keep DLP in simulation until the pilot passes.

Global Requirements — Microsoft Purview Solutions

These requirements apply to **every** solution in the **Purview** category (implementing and managing Microsoft Purview, sensitivity & retention labels, DLP, data lifecycle & records, insider risk, communication compliance, audit, data security posture management, and data governance). Verify each before starting a solution's implementation steps.

Vendor boundary (applies to every Purview solution). *The* ***Microsoft Purview portal*** *(purview.microsoft.com), the* ***Microsoft 365 admin center****,* ***Security & Compliance PowerShell*** *(`Connect-IPPSSession`), and* ***Microsoft Graph*** *are authored at exact, current click-by-click / cmdlet detail from Microsoft's public documentation. Microsoft Purview features are heavily* ***licensing-/plan-dependent*** *(many require* ***Microsoft 365 E5*** *or the* ***E5 Compliance*** *add-on; some are in preview) and the portal is* ***actively evolving*** *— capability availability and portal paths are* ***cited or flagged "verify your licensing/tenant"****, never asserted or invented.* ***Regulatory, records-retention, and legal determinations*** *(retention schedules, records file plans, legal holds, insider-risk case actions, regulatory applicability) are* ***deferred to the organization's compliance, records, privacy, and legal functions*** *— the solutions provide the technical configuration method and evidence, not the determination. Automation is* ***PowerShell*** *(Security & Compliance PowerShell / Graph) — never with hardcoded credentials or secrets.*

1. Microsoft 365 tenant with the required Purview/compliance licensing

• **Description:** A Microsoft 365 tenant with the **compliance licensing** the capability requires

(E3 for baseline; **E5 / E5 Compliance** for advanced DLP, auto-labeling, insider risk, communication compliance, Audit Premium, DSPM, etc.).

• **Why required:** Most Purview capabilities are plan-gated; the feature won't be available without the

right plan.

• **How to verify:** In the M365 admin center confirm the subscription/add-ons; check the feature is

visible in the Purview portal.

• **How to implement if missing:** Assign/purchase the required licensing before starting.

2. Purview roles (least-privilege) and portal access

• **Description:** Access with the least-privilege **Purview / compliance role** the solution names

(e.g. Compliance Administrator, Compliance Data Administrator, Information Protection, Records Management, Insider Risk, eDiscovery, Audit roles), with Global Administrator only where required.

• **Why required:** Purview uses fine-grained role groups; configuration requires the matching role.

• **How to verify:** Purview portal → **Roles & scopes / Permissions** — confirm the role membership.

• **How to implement if missing:** Assign the least-privilege role group under change control.

3. Security & Compliance PowerShell + Graph toolchain

• **Description:** A workstation with **Security & Compliance PowerShell** (`Connect-IPPSSession` via the

ExchangeOnlineManagement module) and **Microsoft Graph PowerShell**, modern-auth / MFA-capable admin.

• **Why required:** Configuration, automation, and the provided scripts run through these.

• **How to verify:** `Connect-IPPSSession` and `Connect-MgGraph` succeed with the admin account.

• **How to implement if missing:** Install the modules and confirm modern-auth sign-in before running steps.

4. Data sources & scope in scope

• **Description:** The **workloads and data sources** in scope (Exchange, SharePoint, OneDrive, Teams, endpoints/devices, and — for data governance — the broader data estate) and a **data-classification / sensitivity** intent to drive labels, DLP, and retention.

• **Why required:** Purview policies key off the in-scope workloads and the classification scheme.

• **How to verify:** Confirm the in-scope workloads and the classification/sensitivity approach with stakeholders.

• **How to implement if missing:** Define the scope and classification intent before authoring policies.

5. Compliance, records, privacy & legal stakeholders

• **Description:** Engagement with the **compliance, records-management, privacy, security, and legal** stakeholders whose policies the configuration must satisfy (retention schedules, records file plans, regulatory obligations, insider-risk and communication-compliance policy, legal hold).

• **Why required:** Purview configuration must align to enterprise policy and legal/records requirements, not technical defaults; several capabilities have HR/legal sensitivity.

• **How to verify:** Confirm the applicable policies, the records schedule, and named approvers.

• **How to implement if missing:** Identify the owners and capture the requirements before configuring.

6. A pilot scope and change control

• **Description:** A **pilot scope** (users/sites/policies in simulation or a limited ring) to validate on before tenant-wide enforcement, and a **change-control** process — most Purview policies support a **simulation / test / disabled** mode that MUST be used before enforcement.

• **Why required:** Every solution follows an **Assess → Design → Configure → Pilot (simulate) → Validate → Expand (enforce)** model; DLP, labels, retention, and insider-risk changes are high-impact.

• **How to verify:** Confirm a named pilot scope, that simulation/test mode is available, and a change window/approval path.

• **How to implement if missing:** Define the pilot and agree change control before enforcing anything.

*The deployment model across every Purview solution is the same: **Assess** → **Design** → **Configure** → **Pilot (simulate/test)** → **Validate** → **Expand (enforce)**, with explicit pass/fail gates and a documented rollback. Automation is delivered as **PowerShell** (Security & Compliance PowerShell / Graph) — never with hardcoded credentials or secrets. Regulatory/records/legal determinations are deferred to the relevant governance functions.*

3. Implementation Guide — Microsoft Purview SOX Compliance Program

Follow these steps **in order**. Configuration uses the **Microsoft Purview portal** (`https://purview.microsoft.com`), **Security & Compliance PowerShell** (`Connect-IPPSSession` — labels, DLP, retention, `*-UnifiedAuditLogRetentionPolicy`), **Exchange Online PowerShell** (`Connect-ExchangeOnline` — `Search-UnifiedAuditLog`, `Get/Set-AdminAuditLogConfig`), and **Microsoft Graph** (licensing/roles). Every write is gated: scripts run **read-only or** `-WhatIf` **by default** and only change state with `-Commit`. Artifact names follow the `<Purpose> – <Scope> – <Stage>` convention from the Overview and are reused verbatim.

> ***Model:*** *Assess the current state, design the SOX-to-Purview control map, configure the controls,* ***pilot*** *on the finance ring in simulation/test, validate each control and its evidence, then expand to enforcement. Pattern:* ***Assess*** *→* ***Design*** *→* ***Configure*** *→* ***Pilot (simulate)*** *→* ***Validate*** *→* ***Expand.*** ***Audit is not retroactive*** *— enable logging before the period you intend to evidence.*

Step 1 — Assess current state and licensing (Assess)

1. Run `PURVSOX-Scope.ps1` (read-only) to confirm connectivity to S&C PowerShell, Exchange Online, and Graph; report the Purview **role groups** and members (Requirement 2.2), the **licensing** that gates advanced DLP/auto-labeling/long-term audit/Compliance Manager (2.1), and whether **Compliance Manager** and **DLP** are reachable (2.6).

2. Run `PURVSOX-Discovery.ps1` (read-only). It reports:

• `UnifiedAuditLogIngestionEnabled` (is the evidence foundation on? — 2.4),

• existing **sensitivity labels** and label policies, **DLP policies** and their **Mode** (Enable/Test/Disable), **retention policies**, and **audit log retention policies**,

• which of the program's named artifacts already exist.

1. Record the gaps. **Pass gate:** you have a written current-state for audit, labels, DLP, retention, audit-retention, roles, and licensing.

Step 2 — Map SOX objectives to Purview controls (Design)

1. With your SOX/ICFR, finance, records, and internal-audit owners (Requirement 2.5), confirm the control map from the Overview — each Purview control to its ITGC objective (access to programs & data, change management, IT operations, segregation of duties, records retention).

2. Agree the **in-scope financial data** (sites/Teams/mailboxes/OneDrive), the **classification intent** for the label, the **records-retention schedule** (their determination), and the **evidence** the external auditor expects.

3. Define the **pilot finance ring** `SOX Pilot – Finance Ring – Stage1` (Requirement 2.7) and the evidence runbooks in scope. **Pass gate:** the control map, scope, retention schedule, and pilot are documented and approved.

Step 3 — Enable the evidence foundation: unified audit (Configure)

1. If Step 1 showed unified audit **off**, enable it under change control:

`PURVSOX-ConfigureControls.ps1 -EnableUnifiedAudit -WhatIf` → review → re-run with `-Commit`. (Runs `Set-AdminAuditLogConfig -UnifiedAuditLogIngestionEnabled $true`; activation can take time.)

1. **Pass gate:** re-run `PURVSOX-Discovery.ps1` — ingestion is `True`. **Rollback:** enabling audit is non-destructive; it can be disabled again under change control, but doing so stops SOX evidence capture — avoid.

Step 4 — Configure the financial-data classification (Configure → Pilot)

1. Create the sensitivity label `Financial – SOX Reporting – Confidential`, **pilot-first**:

`PURVSOX-ConfigureControls.ps1 -Control Label -Name "Financial – SOX Reporting – Confidential" -WhatIf` → review the exact `New-Label` it would run → `-Commit`.

1. Publish it to the pilot ring only (limited-scope label policy), not tenant-wide:

`PURVSOX-ConfigureControls.ps1 -Control LabelPolicy -Name "Financial – SOX Reporting – Confidential" -PilotUsers "financepilot@contoso.com" -WhatIf` → `-Commit`. (Auto-labeling, if licensed, is configured in **simulation mode** in the portal before it is turned on — 2.1.)

1. **Pass gate:** the label appears for pilot users and can be applied to a test financial document. **Rollback:** unpublish the label policy (`Remove` the scoped policy); the label definition can remain unpublished.

Step 5 — Configure the financial-data DLP policy in SIMULATION (Configure → Pilot)

1. Create the DLP policy `DLP – SOX Financial Data – Simulation` **in test/simulation mode** (never enforce first):

`PURVSOX-ConfigureControls.ps1 -Control Dlp -Name "DLP – SOX Financial Data – Simulation" -Workloads SharePoint,OneDrive,Exchange -PilotUsers "financepilot@contoso.com" -WhatIf` → review → `-Commit`. The script creates the policy with `-Mode TestWithNotifications` and a rule that keys off the `Financial – SOX Reporting – Confidential` label (and/or financial sensitive-info types you specify) — so it **reports** matches without blocking.

1. Let it run over the pilot window to gather exposure evidence. **Pass gate:** `PURVSOX-Validate.ps1` shows the policy in a **Test** mode and DLP simulation is registering matches. **Rollback:** `PURVSOX-ConfigureControls.ps1 -Control Dlp -Name "…" -Remove -Commit`.

Step 6 — Configure SOX records retention (Configure → Pilot)

1. Create the retention policy `Retention – SOX Financial Records – Governed` on the **pilot scope**, with the **duration your records/legal function set** (their determination — Requirement 2.5):

`PURVSOX-ConfigureControls.ps1 -Control Retention -Name "Retention – SOX Financial Records – Governed" -Workloads SharePoint -PilotSites`

`"https://contoso.sharepoint.com/sites/FinancePilot" -RetainDays 2555 -WhatIf` → review → `-Commit`. (`-RetainDays` is a placeholder you set from the schedule; the script does **not** invent a period.)

1. **Pass gate:** the retention policy exists scoped to the pilot with the agreed duration/action. **Rollback:** `-Remove -Commit` (already-retained content ages out by remaining rules). **Note:** disposition/records **file-plan** determinations are deferred — this configures retention, it does not decide the schedule.

Step 7 — Configure the financial-access audit retention policy (Configure)

1. Create `Audit Retention – Financial Data Access – SOX` so the access/change trail is kept for the review period, **pilot-first**:

`PURVSOX-ConfigureControls.ps1 -Control AuditRetention -Name "Audit Retention – Financial Data Access – SOX" -RecordTypes SharePointFileOperation,ExchangeItem -Duration OneYear -Priority 150 -WhatIf` → review → `-Commit`. **Verify accepted** `RetentionDuration` **values and that any long-term tier is licensed in your tenant** (2.1) before committing; priorities must be **unique** (lower = evaluated first).

1. **Pass gate:** `PURVSOX-Discovery.ps1` lists the policy with the expected duration/priority. **Rollback:** `-Control AuditRetention -Name "…" -Remove -Commit`.

Step 8 — Map the controls in Compliance Manager (Configure)

1. In the Purview portal → **Compliance Manager**, add the SOX/ICFR (or a custom) assessment and name it `SOX ICFR – Purview Controls – Assessment` (Requirement 2.6). **Verify a suitable template is available for your licensing/tenant**; if not, use a custom assessment.

2. For each improvement action that the Purview controls satisfy (classification, DLP, audit, retention, access), attach the **evidence** the runbooks produce (Step 9) and mark implementation/test status with your reviewer (kept separate from the configurer — SoD, 2.2). **Pass gate:** the assessment reflects the configured controls with linked evidence.

Step 9 — Build the evidence runbooks (Configure)

Encode the auditor's recurring requests as saved, repeatable searches — each a documented set of `PURVSOX-EvidenceReport.ps1` / `Search-UnifiedAuditLog` invocations with a short "what this answers":

1. `Evidence – Financial Data Access – Runbook`: who accessed labeled financial content? → operations `FileAccessed,FileDownloaded,FileSyncDownloadedFull` on the in-scope SharePoint/OneDrive sites; correlate with the label.

2. `Evidence – Control Change Management – Runbook`: who changed a DLP/label/retention/role configuration? → operations `New-DlpCompliancePolicy,Set-DlpCompliancePolicy,New-Label,Set-Label,New-RetentionCompliancePolicy,Set-RetentionCompliancePolicy,Add member to role.` (change management ITGC).

3. `Evidence – Access Provisioning – Runbook`: who was granted access to financial data? → operations `Add member to group.,Add member to role.,SharingInvitationCreated,AnonymousLinkCreated` scoped to the finance sites.

4. Store each runbook (exact commands + interpretation notes) alongside this guide. **Pass gate:** each runbook returns interpretable results for benign/test activity over the pilot scope.

Step 10 — Validate the program and its evidence (Validate)

1. Run `PURVSOX-Validate.ps1` (read-only) to confirm each control is in its expected state: audit on, label published to pilot, **DLP in a Test/simulation mode**, retention scoped with the agreed duration, audit-retention policy present.

2. Run `PURVSOX-EvidenceReport.ps1` to produce `SOX Program – Purview Controls – Report` — a control-to-evidence scorecard, and walk each runbook (Step 9). Complete the **Testing Guide** before expanding.

3. **Pass gate:** the report is green on every control for the pilot and each evidence runbook produces its artifact.

Step 11 — Expand to enforcement and operationalize (Expand)

1. Once the pilot passes and exposure evidence is reviewed, move the DLP policy from **simulation to enforce** (`-Control Dlp -Name "…" -SetMode Enable -WhatIf` → `-Commit`) and extend the label, retention, and audit-retention coverage to the full agreed scope.

2. Schedule the read-only chain (`PURVSOX-Discovery.ps1` → `PURVSOX-Validate.ps1` → `PURVSOX-EvidenceReport.ps1`) on a cadence so control drift — DLP flipped off, audit disabled, a policy removed, a role change — is caught between audits, and re-run the evidence runbooks when the auditor requests a period.

3. Hand the control map, the assessment, and the evidence runbooks to your SOX/ICFR and internal-audit owners as the standing program. **Pass gate:** enforcement is live for the agreed scope, evidence is producible on demand, and the monitoring cadence is scheduled.

5. Testing & Validation — Microsoft Purview SOX Compliance Program

Work through every gate. Each has a **method**, an **expected result (pass)**, and a **fail action**. Tests are read-only or use benign, self-generated activity on the pilot scope — no production data is altered and DLP stays in **simulation** until the pilot passes. Do not declare the program "in place" until every gate passes for `SOX Pilot – Finance Ring – Stage1`, then re-confirm on expand.

> ***Remember:*** *the audit trail is not retroactive — these gates confirm capture, controls, and evidence* ***from now forward****, and prove the technical configuration operates,* ***not*** *that the SOX control design or retention schedule is correct (those are management/internal-audit/records/legal determinations).*

Gate 1 — Unified audit logging is on (evidence foundation)

- **Method:** `PURVSOX-Discovery.ps1`, or `Get-AdminAuditLogConfig | FL UnifiedAuditLogIngestionEnabled` (Exchange Online PowerShell).
- **Pass:** `UnifiedAuditLogIngestionEnabled = True`.

• **Fail:** enable via `PURVSOX-ConfigureControls.ps1 -EnableUnifiedAudit -Commit` (Implementation Step 3); allow activation time, then retest.

Gate 2 — Licensing supports the advanced controls

• **Method:** `PURVSOX-Scope.ps1` licensing section (Graph `subscribedSkus` / service plans).

• **Pass:** E5 / E5-Compliance-bearing plans are present for the users who need advanced DLP, auto-labeling, long-term audit retention, and Compliance Manager templates.

• **Fail:** proceed with the baseline controls (manual labels, Audit Standard, basic retention) and flag the gated controls as "pending licensing" — an unlicensed advanced control is a licensing fact, not a defect.

Gate 3 — Financial-data label exists and applies on the pilot

• **Method:** `PURVSOX-Validate.ps1` (label section, `Get-Label` / `Get-LabelPolicy`); as a pilot user, apply `Financial – SOX Reporting – Confidential` to a test document.

• **Pass:** the label exists, is published to the pilot ring, and applies to test financial content.

• **Fail:** create/publish with `PURVSOX-ConfigureControls.ps1 -Control Label`/`-Control LabelPolicy` (Step 4); allow label-policy propagation time before concluding.

Gate 4 — DLP policy is present and in SIMULATION mode

• **Method:** `PURVSOX-Validate.ps1` (DLP section, `Get-DlpCompliancePolicy | FL Name,Mode`).

• **Pass:** `DLP – SOX Financial Data – Simulation` exists with **Mode** = a Test/simulation value (`TestWithNotifications`/`TestWithoutNotifications`) — **not** `Enable` — during the pilot.

• **Fail:** create with `PURVSOX-ConfigureControls.ps1 -Control Dlp` (Step 5); if it is already `Enable` before the pilot passed, set it back to test (`-SetMode TestWithNotifications -Commit`).

Gate 5 — DLP simulation is registering matches

• **Method:** generate benign test content that matches the rule (a document carrying the financial label / a financial sensitive-info type) in a pilot location; check DLP **simulation/alerts** in the portal, or the audit trail for DLP rule matches.

• **Pass:** the simulation shows matches for the test content (evidence of exposure) without blocking.

• **Fail:** confirm the rule's conditions (label / SIT) actually match the test content and the workloads are in scope; allow processing latency before concluding.

Gate 6 — SOX records retention policy is scoped and correct

• **Method:** `PURVSOX-Validate.ps1` (retention section, `Get-RetentionCompliancePolicy`/`Get-RetentionComplianceRule`).

• **Pass:** `Retention – SOX Financial Records – Governed` exists on the pilot scope with the **duration/action your records function set**.

• **Fail:** create/correct with `PURVSOX-ConfigureControls.ps1 -Control Retention` (Step 6); confirm the duration came from the records schedule, not a default.

Gate 7 — Financial-access audit retention policy exists

• **Method:** `PURVSOX-Discovery.ps1` retention section (`Get-UnifiedAuditLogRetentionPolicy`).

• **Pass:** `Audit Retention – Financial Data Access – SOX` exists with the agreed record types, duration, and a unique priority.

• **Fail:** create/correct with `PURVSOX-ConfigureControls.ps1 -Control AuditRetention` (Step 7); verify the `RetentionDuration` value and any long-term licensing.

Gate 8 — Evidence runbooks answer the auditor's questions

• **Method:** walk each runbook (Implementation Step 9) against benign/test activity over the pilot — financial-data access (`FileAccessed`/`FileDownloaded`), control change (`Set-DlpCompliancePolicy`, `New-Label`, role adds), access provisioning (group/role adds, sharing).

• **Pass:** each runbook returns interpretable results — the artifact an auditor would request.

• **Fail:** confirm the operation/record-type names and that logging covers the scope; adjust the runbook and retest (allow ingestion latency).

Gate 9 — Segregation of duties on the controls themselves

• **Method:** `PURVSOX-Scope.ps1` role section — review who configures vs who reviews evidence for the SOX controls.

• **Pass:** the configuring role and the evidence-reviewing role are held by different parties (documented); Global Admin is not used for routine control work.

• **Fail:** separate the roles under change control; record the separation in the Compliance Manager assessment.

Gate 10 — Compliance Manager assessment reflects the controls

• **Method:** Purview portal → Compliance Manager → `SOX ICFR – Purview Controls – Assessment`.

• **Pass:** the improvement actions the Purview controls satisfy are marked with linked evidence and reviewer status.

• **Fail:** attach the runbook evidence and update status; if no template is licensed, confirm the custom mapping is maintained (Requirement 2.6).

Gate 11 — Program scorecard is green (pilot, then tenant-wide)

- **Method:** `PURVSOX-EvidenceReport.ps1` → `SOX Program – Purview Controls – Report`.
- **Pass:** every control gate above is green for the pilot scope (and, on expand, for the full agreed scope with DLP in **enforce**).
- **Fail:** address the specific red control and re-run.

Evidence to retain

- `PURVSOX-Scope.ps1`, `PURVSOX-Discovery.ps1`, and `PURVSOX-EvidenceReport.ps1` outputs (before/after).
- The `-WhatIf` transcripts for every label, DLP, retention, and audit-retention change.
- The DLP **simulation** results demonstrating exposure before enforcement.
- The runbook results demonstrating each auditor question is answerable, and the change approvals (Requirement 2.5/2.7).

*Control-design adequacy, operating-effectiveness conclusions, materiality, and retention-schedule sufficiency are **management, internal-audit, records, and legal determinations** — these gates prove the Purview configuration operates and its evidence is producible, not that the SOX program is compliant.*

6. Troubleshooting — Microsoft Purview SOX Compliance Program

The failure modes you'll hit building and maintaining a SOX/ICFR program in Purview. Each: **symptom** → **likely cause** → **fix.** Most "the control isn't there" reports are actually licensing, a DLP policy in the wrong mode, audit that was enabled too late, or evidence that was never linked — this guide separates those from real faults. Automation is **Security & Compliance PowerShell** (`Connect-IPPSSession`) plus **Exchange Online PowerShell** (`Connect-ExchangeOnline`) for the audit config and unified audit log.

Unified audit evidence is empty for the review period (the foundation)

- **Cause:** unified audit logging was enabled **after** the activity, or wasn't on — **audit is not retroactive**. Fix:** enable it now (`PURVSOX-ConfigureControls.ps1 -EnableUnifiedAudit -Commit`); evidence accrues from enablement forward. There is no way to recover events from before logging was on — capture this fact in the program rather than presenting a gap as coverage.

The financial-data label doesn't appear for pilot users

- **Cause A — not published.** The label exists but no label policy publishes it to the pilot ring.

Fix: run `PURVSOX-ConfigureControls.ps1 -Control LabelPolicy -PilotUsers "…"` (Step 4).

- **Cause B — propagation latency.** Label-policy changes take time to reach clients. **Fix:** allow propagation, then retest applying `Financial – SOX Reporting – Confidential` to a test document.

The DLP policy is blocking users during the pilot

- **Cause:** the policy was created or flipped to **Enable** (enforce) instead of simulation. During the

pilot it must be `TestWithNotifications` (simulation — reports without blocking).

- **Fix:** confirm `Get-DlpCompliancePolicy "DLP – SOX Financial Data – Simulation" | FL Name,Mode`; set

it back with `PURVSOX-ConfigureControls.ps1 -Control Dlp -Name "…" -SetMode TestWithNotifications -Commit` until the pilot passes, then promote to enforce deliberately (Step 11). Always `-WhatIf` first.

DLP simulation shows no matches for financial content you expect it to catch

- **Cause A — condition mismatch.** The rule keys off the `Financial – SOX Reporting – Confidential`

label (and/or financial SITs); the test content doesn't carry the label or match the SIT. **Fix:** confirm the test document is labeled / matches, and the workloads (SharePoint/OneDrive/Exchange) are in scope.

- **Cause B — propagation latency.** New/changed DLP policies take time to evaluate content. **Fix:**

allow time, retest.

Retention or audit-retention create fails on duration or priority

- **Cause A — duration/licensing.** The `RetentionDuration` value isn't accepted for your plan, or a

long-term tier is requested without the add-on. **Fix:** verify accepted `RetentionDuration` values and licensing (Requirement 2.1) before `-Commit`. The retention **period comes from your records schedule — the script does not invent one.**

- **Cause B — duplicate priority.** Audit-retention priorities must be **unique**. **Fix:** pick an

unused priority (lower = evaluated first).

Retention-policy / DLP / label cmdlet "term is not recognized"

- **Cause:** wrong endpoint. `*-DlpCompliancePolicy`, `*-Label`, `*-RetentionCompliancePolicy`, and

`*-UnifiedAuditLogRetentionPolicy` are **S&C PowerShell** (`Connect-IPPSSession`); `Get/Set-AdminAuditLogConfig` and `Search-UnifiedAuditLog` are **Exchange Online** (`Connect-ExchangeOnline`). **Fix:** connect the right endpoint; both ship in `ExchangeOnlineManagement`.

An evidence runbook returns nothing for activity you know happened

- **Cause A — operation/record-type name.** The operation name doesn't match how the workload logs it

(names vary by workload/version). **Fix:** confirm the exact operation via a broad `Search-UnifiedAuditLog` first, then narrow the runbook.

- **Cause B — ingestion latency / scope.** The event hasn't ingested yet, or the site filter excludes it. **Fix:** allow ingestion latency; widen `-Days`; confirm `-FinanceSites` matches the real site URL.
- **Cause C — logging coverage.** The record type wasn't being captured. **Fix:** confirm unified audit is on and the audit-retention policy covers those record types (Step 7).

Compliance Manager score didn't move after configuring a control

- **Cause:** the improvement action's **evidence/implementation status wasn't updated** in the portal.

Compliance Manager scores off recorded improvement-action status, not raw tenant state. **Fix:** attach the runbook artifact and set the action's status in the portal (Step 8); scores update on the portal's cadence. Keep the **reviewer separate from the configurer** (SoD).

Segregation-of-duties gate fails — same person configures and reviews

- **Cause:** the configuring role and the evidence-reviewing role are held by one identity, or Global Admin is used for routine control work. **Fix:** separate the roles under change control (`PURVSOX-Scope.ps1` shows role membership); record the separation in the Compliance Manager assessment. This is an ITGC control in its own right.

When to escalate beyond this solution

- **Control-design adequacy, operating-effectiveness conclusions, materiality, and whether the evidence satisfies the external auditor → management / internal audit** (this solution configures and evidences the controls; the SOX conclusions are theirs — deferred).
- **Records-retention schedule adequacy / disposition / file-plan → records, legal, and finance** (this configures retention; it does not decide the schedule).
- **A capability genuinely missing despite correct licensing** → verify against current Microsoft documentation and open a Microsoft support case; Compliance Manager templates and Purview capabilities evolve.

7. Best Practices — A Defensible SOX Program in Microsoft Purview

Operating principles for keeping the SOX-aligned Purview controls trustworthy and their evidence audit-ready. Grounded in Microsoft's public guidance and the **Assess → Design → Configure → Pilot (simulate) → Validate → Expand** model.

Treat evidence as the deliverable, not the control

• An auditor tests whether a control **operated over the period** — that needs an **artifact**. Configure each Purview control so it *produces* evidence (an in-force policy, an audit trail, a simulation report), and store the evidence runbooks so the artifact is reproducible on demand.

• **The audit trail is not retroactive.** Enable unified audit logging before the review period, and treat "is audit on?" as a **standing monitored control** — the scheduled discovery/validate chain catches it being turned off between audits.

Map controls to objectives explicitly — and keep the map current

• The backbone of a SOX program is the **control-to-objective map** (Purview control → ITGC objective). Maintain it in **Compliance Manager** (or a custom assessment) so leadership and the external auditor see the same rollup.

• Purview covers **classification, DLP, retention, and the M365 audit trail** — it does **not** replace ERP/application access controls, SoD tooling, or change-management systems. Show the boundary clearly so the auditor knows what Purview does and doesn't evidence.

Pilot every high-impact control — DLP in simulation, always

• **DLP goes into simulation/test mode first.** Simulation gives you exposure evidence (what *would* have been blocked) with zero disruption — invaluable for both scoping and the audit narrative. Move to enforce only after the pilot passes and the exposure is reviewed.

• Publish labels and retention to a **finance-ring pilot** before tenant-wide; validate with the readiness report before expansion. Every change is reversible — record the exact rollback with it.

Classify deliberately, then let protection key off the label

• One clear label for financial reporting data (`Financial – SOX Reporting – Confidential`) lets DLP, retention, and monitoring all reference the same classification — simpler to explain and to audit than scattered ad-hoc rules.

• Where licensed, use **auto-labeling in simulation** to find financial data at scale before you trust the classification — verify the simulation before enabling.

Retention: configure to the schedule, never invent one

• SOX record-retention periods (including audit-workpaper retention under §802) and which data is financially relevant are **records/legal determinations**. Configure retention to their schedule; the scripts take the period as a parameter and never assume one.

• Keep **disposition and file-plan** decisions with records management — this program configures retention and produces evidence, it does not decide the schedule or dispose of records.

Segregation of duties — on the ERP *and* on Purview itself

• SoD is a SOX control that also applies to the controls' own administration: the person who **configures** a Purview control should not be the sole party who **reviews its evidence**. Assign least-privilege role groups and separate configure-vs-review.

• Access to the audit log and to control configuration is itself sensitive — review role membership periodically, and remember configuration changes are themselves logged (that's the change-management evidence).

Watch the gotchas that undermine SOX evidence

• **Ingestion latency** — recent activity isn't searchable immediately; widen the window before concluding an event is absent.

• **Search truncation** — `Search-UnifiedAuditLog` caps results; page (`ReturnLargeSet`) and keep windows short so evidence is never silently incomplete.

• **UTC timestamps** — audit `CreationDate` is UTC; normalize when correlating with ERP, sign-in, or change-management logs so the timeline holds up.

• **License lapse** — advanced DLP/auto-labeling/long-term audit retention/Compliance Manager depend on E5/E5-Compliance; a lapse silently degrades a control. The scheduled scope check flags it.

Monitor for drift between audits

• Schedule the read-only `PURVSOX-Discovery.ps1` → `PURVSOX-Validate.ps1` → `PURVSOX-EvidenceReport.ps1` chain so a control flipping off, a policy being removed, DLP dropping to disabled, or a role change is caught early — not discovered during the audit.

• Re-run the evidence runbooks when the external auditor requests a period, and keep the `-WhatIf` transcripts and simulation reports as the change record.

Verify against your tenant — Purview evolves

• Capability availability, portal paths, Compliance Manager templates, and accepted `RetentionDuration` values are **licensing-/tenant-dependent and change over time**. Confirm against your entitlements and current Microsoft documentation before standardizing any automation or promising a capability.

8. Deliverables Summary — Microsoft Purview SOX Compliance Program

What you receive, what to run, and what "done" looks like.

Documentation

Document	Purpose
1. Solution Overview	What a SOX-aligned Purview program is, the Purview→ITGC control map, the evidence runbooks, what you control, honest limitations, and the naming convention.

Document	Purpose
2. Requirements Guide	SOX-specific prerequisites (compliance licensing, least-privilege roles with SoD, S&C + Exchange + Graph toolchain, unified audit, defined financial scope & records schedule, Compliance Manager, pilot) — each with Verify / Implement.
3. Implementation Guide	Ordered steps: assess, map controls, enable audit, configure label / DLP-in-simulation / retention / audit-retention, map in Compliance Manager, build evidence runbooks, validate, expand to enforce — pilot-first with pass/fail gates and rollback.
5. Testing & Validation	Eleven gates from "audit on" to "program scorecard green," each with method / pass / fail action.
6. Troubleshooting	The failure modes that break SOX evidence — DLP enforcing too early, latency, truncation, licensing, endpoint confusion, retention scoping — and their fixes.
7. Best Practices	Defensible-program operating principles: evidence as the deliverable, explicit control mapping, DLP-in-simulation, deliberate classification/retention, SoD, drift monitoring.

PowerShell tools (5)

All run **read-only or `-WhatIf` by default**; writes require `-Commit`. No credentials or secrets are embedded. Label / DLP / retention / audit-retention cmdlets use **Security & Compliance PowerShell** (`Connect-IPPSSession`); audit search/config uses **Exchange Online PowerShell** (`Connect-ExchangeOnline`); licensing/role reads use **Microsoft Graph**.

Script	Role	Default
`PURVSOX-Scope.ps1`	Assess/health: connectivity, Purview role groups + SoD review, licensing (E5/E5-Compliance), Compliance Manager/DLP reachability, pilot scope.	Read-only
`PURVSOX-Discovery.ps1`	Assess: unified-audit state, existing labels / DLP (+ Mode) / retention / audit-retention policies, which named artifacts already exist.	Read-only
`PURVSOX-ConfigureControls.ps1`	Configure/Remediate: enable unified audit; create/update/remove the label, DLP (**simulation/test first**), retention, and audit-retention controls.	`-WhatIf` (writes on `-Commit`)

Script	Role	Default
`PURVSOX-Validate.ps1`	Validate: confirm each control exists and is in its expected state (audit on, label published, **DLP in Test mode**, retention scoped, audit-retention present).	Read-only
`PURVSOX-EvidenceReport.ps1`	Report: control-to-evidence scorecard + run the evidence runbooks (paged `Search-UnifiedAuditLog`, no silent truncation) and export.	Read-only

Named artifacts created

• Controls: `Financial – SOX Reporting – Confidential` (label), `DLP – SOX Financial Data – Simulation` (DLP, simulation-first), `Retention – SOX Financial Records – Governed` (retention), `Audit Retention – Financial Data Access – SOX` (audit retention).

• Control mapping: `SOX ICFR – Purview Controls – Assessment` (Compliance Manager).

• Evidence runbooks: `Evidence – Financial Data Access – Runbook`, `Evidence – Control Change Management – Runbook`, `Evidence – Access Provisioning – Runbook`.

• Program export: `SOX Program – Purview Controls – Report`. Pilot scope: `SOX Pilot – Finance Ring – Stage1`.

Definition of done

• Unified audit logging **on** (the evidence foundation), enabled before the review period.

• The financial-data **label** published to the pilot and applying to test content.

• The financial-data **DLP** policy in **simulation**, registering matches — then moved to **enforce** after the pilot passes and exposure is reviewed.

• The SOX **retention** policy scoped with the records-function's duration; the **audit-retention** policy in place.

• The controls **mapped in Compliance Manager** with linked evidence, **SoD** separation documented, and each **evidence runbook** proven to produce its artifact.

• The **program scorecard green** for the pilot — then expanded to the agreed scope with a monitoring cadence scheduled.

Boundary: *this solution delivers the technical configuration and evidence.* ***SOX control-design adequacy, operating-effectiveness conclusions, materiality, record-retention schedules, and legal holds are deferred to your management, internal-audit, records, and legal functions*** *— it is not an audit or an attestation. Feature availability is* ***licensing-/tenant-dependent and evolving — verify against your entitlements and current Microsoft documentation.***

Appendix A — PowerShell Scripts

Included in the accompanying ZIP. Each script's header documents full usage.

PURVSOX-ConfigureControls.ps1

Purpose: Configuration/remediation helper for the SOX-aligned Purview controls. With -EnableUnifiedAudit it turns unified audit ingestion on. With -Control it creates/updates/removes one control: a sensitivity Label, a scoped LabelPolicy, a DLP policy (created in TEST/SIMULATION mode), a Retention policy (period supplied by you — never invented), or an audit-log AuditRetention policy. SAFE BY DEFAULT: prints the exact change under -WhatIf; only writes with -Commit. HOW TO RUN Enable the evidence foundation (preview then commit): .\PURVSOX-ConfigureControls.ps1 -EnableUnifiedAudit -WhatIf Create the financial-data DLP policy in SIMULATION (preview then commit): .\PURVSOX-ConfigureControls.ps1 -Control Dlp -Name "DLP – SOX Financial Data – Simulation" ` -Workloads SharePoint,OneDrive,Exchange -PilotUsers "financepilot@contoso.com" -WhatIf .\PURVSOX-ConfigureControls.ps1 -Control Dlp -Name "DLP – SOX Financial Data – Simulation" ... -Commit Later, move DLP from simulation to enforce (after the pilot passes): .\PURVSOX-ConfigureControls.ps1 -Control Dlp -Name "DLP – SOX Financial Data – Simulation" -SetMode Enable -Commit Uses Exchange Online PowerShell for -EnableUnifiedAudit; Security & Compliance PowerShell (Connect-IPPSSession) for labels/DLP/retention/audit-retention. No secrets in code. EXPECTED RESULTS Under -WhatIf: the exact cmdlet(s) that would run and their parameters. Under -Commit: the control is created/updated/removed and the resulting object is printed. DLP is created in TestWithNotifications (simulation) unless you explicitly -SetMode Enable. .NOTES Purview category — SOX Compliance Program. DLP MUST be piloted in simulation before enforce. Retention DURATION is your records/legal determination — supplied via -RetainDays; the script does not assume one. RetentionDuration values and any long-term audit tier are licensing-dependent; verify in your tenant before -Commit. > [CmdletBinding()] param([switch]$EnableUnifiedAudit,

How to run: Enable the evidence foundation (preview then commit): .\PURVSOX-ConfigureControls.ps1 -EnableUnifiedAudit -WhatIf Create the financial-data DLP policy in SIMULATION (preview then commit): .\PURVSOX-ConfigureControls.ps1 -Control Dlp -Name "DLP – SOX Financial Data – Simulation" ` -Workloads SharePoint,OneDrive,Exchange -PilotUsers "financepilot@contoso.com" -WhatIf .\PURVSOX-ConfigureControls.ps1 -Control Dlp -Name "DLP – SOX Financial Data – Simulation" ... -Commit Later, move DLP from simulation to enforce (after the pilot passes): .\PURVSOX-ConfigureControls.ps1 -Control Dlp -Name "DLP – SOX Financial Data – Simulation" -SetMode Enable -Commit Uses Exchange Online PowerShell for -EnableUnifiedAudit; Security & Compliance PowerShell (Connect-IPPSSession) for labels/DLP/retention/audit-retention. No secrets in code. EXPECTED RESULTS Under -WhatIf: the exact cmdlet(s) that would run and their parameters. Under -Commit: the control is created/updated/removed and the resulting object is printed. DLP is created in TestWithNotifications (simulation) unless you explicitly -SetMode Enable. .NOTES Purview category — SOX Compliance Program. DLP MUST be piloted in simulation before enforce. Retention DURATION is your records/legal determination — supplied via -RetainDays; the script does not assume one. RetentionDuration values and any long-term audit tier are licensing-dependent; verify in your tenant before -Commit. > [CmdletBinding()] param([switch]$EnableUnifiedAudit,

PURVSOX-Discovery.ps1

Purpose: Reports the current state with no changes: whether unified audit log ingestion is on, and the existing sensitivity labels/label policies, DLP policies (with their Mode), retention policies, and audit log retention policies — flagging which of this program's named artifacts already exist. Read-only. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\PURVSOX-Discovery.ps1 Requires the ExchangeOnlineManagement module (Connect-IPPSSession for labels/DLP/retention/ audit-retention; Connect-ExchangeOnline for the audit-config read). Interactive modern-auth / MFA admin sign-in; no secrets in code. EXPECTED RESULTS A posture summary: UnifiedAuditLogIngestionEnabled True/False; tables of labels, DLP policies + Mode, retention policies, and audit retention policies; and a checklist of which program artifacts (label, DLP, retention, audit-retention) are already present. .NOTES Purview category — SOX Compliance Program. Read-only. DLP Mode of TestWithNotifications/ TestWithoutNotifications means SIMULATION (reports without blocking); Enable means enforcing. Feature availability is licensing-/tenant-dependent and evolving. > [CmdletBinding()] param([string]$UserPrincipalName)

How to run: powershell -ExecutionPolicy Bypass -File .\PURVSOX-Discovery.ps1 Requires the ExchangeOnlineManagement module (Connect-IPPSSession for labels/DLP/retention/ audit-retention; Connect-ExchangeOnline for the audit-config read). Interactive modern-auth / MFA admin sign-in; no secrets in code. EXPECTED RESULTS A posture summary: UnifiedAuditLogIngestionEnabled True/False; tables of labels, DLP policies + Mode, retention policies, and audit retention policies; and a checklist of which program artifacts (label, DLP, retention, audit-retention) are already present. .NOTES Purview category — SOX Compliance Program. Read-only. DLP Mode of TestWithNotifications/ TestWithoutNotifications means SIMULATION (reports without blocking); Enable means enforcing. Feature availability is licensing-/tenant-dependent and evolving. > [CmdletBinding()] param([string]$UserPrincipalName)

PURVSOX-EvidenceReport.ps1

Purpose: Read-only. Two outputs: (1) SOX Program - Purview Controls - Report — a control-to-evidence scorecard reading live state (audit on, label published, DLP present + mode, retention scoped, audit-retention present); (2) the auditor evidence runbooks over a bounded window via Search-UnifiedAuditLog — Financial Data Access (FileAccessed/FileDownloaded), Control Change Management (Set-DlpCompliancePolicy/New-Label/role adds), and Access Provisioning (group/role adds, sharing). It reads and summarizes only — it never changes a control and never rules on SOX adequacy. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\PURVSOX-EvidenceReport.ps1 -Days 7 -OutputFolder .\PURVSOX-out .\PURVSOX-EvidenceReport.ps1 -Days 30 -FinanceSites "https://contoso.sharepoint.com/sites/FinancePilot" -OutputFolder .\PURVSOX-out Requires ExchangeOnlineManagement (Connect-IPPSSession + Connect-ExchangeOnline). Interactive modern-auth / MFA admin; no secrets in code. EXPECTED RESULTS A printed scorecard (one row per control with PRESENT/GAP), and one CSV per runbook of the benign/ test activity in the window. PASS = every control PRESENT and each runbook returns interpretable rows for the pilot scope. Audit is not retroactive — only activity after logging was enabled appears. .NOTES Purview category — SOX Compliance Program. Read-only. Control-design adequacy, operating-effectiveness, materiality, and retention-schedule sufficiency are management/internal-audit/records/legal determinations — DEFERRED. Feature availability is licensing-/tenant-dependent. No cmdlets invented. > [CmdletBinding()] param([string]$UserPrincipalName, [ValidateRange(1,90)][int]$Days = 7, [string[]]$FinanceSites, # optional SharePoint site URL filter for access/provisioning [string]$LabelName = 'Financial – SOX Reporting – Confidential', [string]$DlpName = 'DLP – SOX Financial Data – Simulation', [string]$RetentionName = 'Retention – SOX Financial Records – Governed', [string]$AuditRetentionName

= 'Audit Retention – Financial Data Access – SOX', [string]$OutputFolder = '.\PURVSOX-out')

How to run: powershell -ExecutionPolicy Bypass -File .\PURVSOX-EvidenceReport.ps1 -Days 7 -OutputFolder .\PURVSOX-out .\PURVSOX-EvidenceReport.ps1 -Days 30 -FinanceSites "https://contoso.sharepoint.com/sites/FinancePilot" -OutputFolder .\PURVSOX-out Requires ExchangeOnlineManagement (Connect-IPPSSession + Connect-ExchangeOnline). Interactive modern-auth / MFA admin; no secrets in code. EXPECTED RESULTS A printed scorecard (one row per control with PRESENT/GAP), and one CSV per runbook of the benign/ test activity in the window. PASS = every control PRESENT and each runbook returns interpretable rows for the pilot scope. Audit is not retroactive — only activity after logging was enabled appears. .NOTES Purview category — SOX Compliance Program. Read-only. Control-design adequacy, operating-effectiveness, materiality, and retention-schedule sufficiency are management/internal-audit/records/legal determinations — DEFERRED. Feature availability is licensing-/tenant-dependent. No cmdlets invented. > [CmdletBinding()] param([string]$UserPrincipalName, [ValidateRange(1,90)][int]$Days = 7, [string[]]$FinanceSites, # optional SharePoint site URL filter for access/provisioning [string]$LabelName = 'Financial – SOX Reporting – Confidential', [string]$DlpName = 'DLP – SOX Financial Data – Simulation', [string]$RetentionName = 'Retention – SOX Financial Records – Governed', [string]$AuditRetentionName = 'Audit Retention – Financial Data Access – SOX', [string]$OutputFolder = '.\PURVSOX-out')

PURVSOX-Scope.ps1

Purpose: Confirms the environment is ready for the SOX-aligned Purview program with no changes: which endpoints (Security & Compliance PowerShell, Exchange Online, Graph) are reachable, the Purview role groups and their members (for segregation-of-duties review), whether E5 / E5-Compliance service plans are present, and whether Compliance Manager / DLP appear licensed. Read-only. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\PURVSOX-Scope.ps1 Requires the ExchangeOnlineManagement module (Connect-IPPSSession) and, for licensing/roles, Microsoft.Graph with delegated Organization.Read.All / RoleManagement.Read.Directory. Uses an interactive modern-auth / MFA admin sign-in; no secrets in code. EXPECTED RESULTS A readiness summary: endpoints reachable Yes/No, the Purview role groups + members to review for SoD, whether an E5/E5-Compliance plan is present, and a reminder to verify Compliance Manager template availability in the portal. Any "verify your licensing/tenant" item is flagged. .NOTES Purview category — SOX Compliance Program. Read-only. Advanced DLP/auto-labeling/long-term audit retention/Compliance Manager templates are licensing-/tenant-dependent and evolving; confirm against your entitlements and current Microsoft documentation. > [CmdletBinding()] param([string]$UserPrincipalName, # optional: admin UPN passed to Connect-* prompts [switch]$SkipGraph # skip the Graph licensing/role section if Graph is unavailable)

How to run: powershell -ExecutionPolicy Bypass -File .\PURVSOX-Scope.ps1 Requires the ExchangeOnlineManagement module (Connect-IPPSSession) and, for licensing/roles, Microsoft.Graph with delegated Organization.Read.All / RoleManagement.Read.Directory. Uses an interactive modern-auth / MFA admin sign-in; no secrets in code. EXPECTED RESULTS A readiness summary: endpoints reachable Yes/No, the Purview role groups + members to review for SoD, whether an E5/E5-Compliance plan is present, and a reminder to verify Compliance Manager template availability in the portal. Any "verify your licensing/tenant" item is flagged. .NOTES Purview category — SOX Compliance Program. Read-only. Advanced DLP/auto-labeling/long-term audit retention/Compliance Manager templates are licensing-/tenant-dependent and evolving; confirm against your entitlements and current Microsoft documentation. > [CmdletBinding()] param([string]$UserPrincipalName, # optional: admin UPN passed to Connect-* prompts [switch]$SkipGraph # skip the Graph licensing/role section if Graph is unavailable)

PURVSOX-Validate.ps1

Purpose: Validates the program's controls without changing anything: unified audit on; the financial-data label published; the DLP policy present and in a TEST/SIMULATION mode (not enforcing) during the pilot; the SOX retention policy scoped and enabled; and the financial-access audit retention policy present. Prints a PASS/FAIL line per control. Read-only. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\PURVSOX-Validate.ps1 Once the pilot is signed off and DLP has been moved to enforce, assert that instead: .\PURVSOX-Validate.ps1 -ExpectDlpEnforced Requires ExchangeOnlineManagement (Connect-IPPSSession + Connect-ExchangeOnline). Interactive modern-auth / MFA admin sign-in; no secrets in code. EXPECTED RESULTS A PASS/FAIL summary across the five controls. During the pilot, DLP PASSES when in a Test mode and FAILS if already Enable; with -ExpectDlpEnforced the logic inverts (Enable = PASS). .NOTES Purview category — SOX Compliance Program. Read-only. Proves the configuration operates, NOT that the SOX control design or retention schedule is adequate (those are management/internal-audit/ records/legal determinations). > [CmdletBinding()] param([string]$UserPrincipalName, [string]$LabelName = 'Financial – SOX Reporting – Confidential', [string]$DlpName = 'DLP – SOX Financial Data – Simulation', [string]$RetentionName = 'Retention – SOX Financial Records – Governed', [string]$AuditRetentionName = 'Audit Retention – Financial Data Access – SOX', [switch]$ExpectDlpEnforced # after pilot sign-off, expect DLP Mode = Enable)

How to run: powershell -ExecutionPolicy Bypass -File .\PURVSOX-Validate.ps1 Once the pilot is signed off and DLP has been moved to enforce, assert that instead: .\PURVSOX-Validate.ps1 -ExpectDlpEnforced Requires ExchangeOnlineManagement (Connect-IPPSSession + Connect-ExchangeOnline). Interactive modern-auth / MFA admin sign-in; no secrets in code. EXPECTED RESULTS A PASS/FAIL summary across the five controls. During the pilot, DLP PASSES when in a Test mode and FAILS if already Enable; with -ExpectDlpEnforced the logic inverts (Enable = PASS). .NOTES Purview category — SOX Compliance Program. Read-only. Proves the configuration operates, NOT that the SOX control design or retention schedule is adequate (those are management/internal-audit/ records/legal determinations). > [CmdletBinding()] param([string]$UserPrincipalName, [string]$LabelName = 'Financial – SOX Reporting – Confidential', [string]$DlpName = 'DLP – SOX Financial Data – Simulation', [string]$RetentionName = 'Retention – SOX Financial Records – Governed', [string]$AuditRetentionName = 'Audit Retention – Financial Data Access – SOX', [switch]$ExpectDlpEnforced # after pilot sign-off, expect DLP Mode = Enable)